# Méthodes simples sans LLM pour l'audit IoT

Références défensives et comparateurs pour LANCE

Recherche documentaire : agent Codex `sans_llm_outils`
Projet LANCE

Dernière révision : 2026-10-07 14:27
Europe/Brussels, UTC+02:00

Exploration et propositions ; aucune expérience exécutée

**Résumé**

Pour mesurer l'apport d'un grand modèle de langage (LLM), la référence doit accomplir la même tâche avec des informations et des critères de succès comparables. Cette revue ciblée de onze sources primaires distingue cinq méthodes : checklist à critères explicites, identification déterministe de services, contrôles protocolaires et templates conditionnels, conformité locale, rapprochement d'inventaire et d'avis produits. Elle recommande d'abord une interprétation hors ligne sur dossiers communs, puis une comparaison aux règles conditionnelles existantes. OpenSCAP et les avis de composants apportent des références utiles, mais leurs entrées locales ou privilégiées empêchent souvent une comparaison directe avec un audit réseau anonyme. La sélection repose sur la précision des sorties et des contre-exemples, sans classement de performance ni gain LLM démontré. Les futurs tests proposés utilisent uniquement des données fournies ou archivées.

## Table des matières

**1 Question, périmètre et état du dépôt** **2**

**2 Méthode de recherche et force des références** **2**

**3 Ce que la sortie permet réellement d'affirmer** **3**

**4 Cinq familles de méthodes simples** **3**

4.1 Checklist contextualisée à critères explicites . . . . . 3

4.2 Inventaire et identification déterministes . . . . . 4

4.3 Contrôles protocolaires et templates conditionnels . . . . . 4

4.4 Conformité locale : OVAL et OpenSCAP . . . . . 5

4.5 Inventaire logiciel et avis structurés : CPE, SBOM, CSAF, VEX . . . . . 5

**5 Sélection proposée et cas de test** **6**

**6 Mesures, exclusions et limites** **7**

**7 Conclusion et prochaines étapes** **8**

**Références** **8**

# 1 Question, périmètre et état du dépôt

Le comité de thèse demande de mesurer la plus-value du LLM face à des méthodes plus simples. La question utile devient : *sur une propriété définie, que gagne-t-on en ajoutant le modèle à une méthode classique compétente ?* Un faible script qui ignore les négatifs ou les erreurs ferait une référence peu informative. À l'inverse, ajouter simultanément de meilleurs outils, une base documentaire et un LLM empêcherait d'attribuer le résultat au modèle.

Cette étude porte sur l'évaluation défensive d'observations et de configurations d'objets connectés (IoT, *Internet of Things*) autorisées. Elle ne propose ni exploitation, ni découverte de nouvelles vulnérabilités par fuzzing, ni automatisation d'intrusion. Aucun réseau, laboratoire ou binaire n'a été exécuté pour cette recherche. Les fiches de tests sont des propositions hors ligne, pas des expériences réalisées.

**Point de départ local.** Les guides D1/A1 du dépôt décrivent **D1, automatisation conditionnelle sans LLM**, et **A1, socle déterministe partagé avec décisions LLM**. Le périmètre actuel couvre les phases d'analyse et de vérification, avec un inventaire public commun et un contrat de preuve partagé. D1 dispose de reprises bornées et de lectures complémentaires ; il réagit donc déjà à certaines observations. Ces faits viennent des guides locaux `docs/benchmark/agent-vs-automation-cli.md` et `agent-vs-automation-campaign.md`, consultés le 7 octobre 2026 ; la présente revue n'a pas revalidé son code ou son déploiement.

Les mêmes guides signalent des connaissances publiques propres aux simulateurs dans les règles partagées. Une victoire d'A1 sur ce socle mesurerait un bénéfice marginal dans cette configuration, sans établir une généralisation à des équipements inconnus. L'étude historique du 27 septembre reste pertinente ; cette contribution élargit surtout les références simples, leurs entrées et les tâches qu'elles peuvent réellement résoudre.

# 2 Méthode de recherche et force des références

Recherche ciblée le 7 octobre 2026 par titre, organisme et mécanisme : National Institute of Standards and Technology (NIST), SP 800-115 et NISTIR 8259A ; documentation officielle d'identification Nmap ; matchers et workflows Nuclei ; définition OVAL et manuel OpenSCAP ; critères CPE de la NVD ; statuts produits CSAF ; inventaire CycloneDX et VEX. Ont été retenues les sources qui précisent une relation observable entre entrée, critère et sortie. Les comparatifs commerciaux et listes de meilleurs scanners sont exclus.

**Pourquoi ces références sont fortes.** Les documents NIST explicitent le périmètre et les limites de l'évaluation, sans prétendre mesurer un outil particulier. Les documentations des moteurs montrent quels mécanismes classiques sont effectivement disponibles ; elles soutiennent leur faisabilité, sans prouver leur qualité sur LANCE. OVAL, CSAF et CycloneDX définissent les données et statuts échangés ; ils évitent de réduire toute sortie à « faille trouvée ». Leur force est contractuelle et méthodologique. Aucun de ces documents n'établit une supériorité empirique sur le LLM.

**Formats cités.** OVAL (*Open Vulnerability and Assessment Language*) exprime des assertions d'état ; XCCDF (*eXtensible Configuration Checklist Description Format*) décrit des checklists. CPE (*Common Platform Enumeration*) nomme les produits ; une SBOM (*Software Bill of Materials*) inventorie leurs composants logiciels. CSAF (*Common Security Advisory Framework*) structure les avis et VEX (*Vulnerability Exploitability eXchange*) leur appréciation dans un contexte produit. La NVD est la *National Vulnerability Database* du NIST.

La lecture a porté sur les sections techniques citées en bibliographie : catégories d'évaluation et limites des scans, tableau des capacités IoT, identification de versions, prédicats de matching et

conditions, modèles OVAL, résultats XCCDF, applicabilité et statuts produits. La NVD a été lue via sa page indexée ; une ouverture ultérieure a renvoyé une page vide. Cette limitation est consignée dans le registre des sources. Les spécifications ne sont pas prétendues lues intégralement.

Le fichier `sans-llm-outils-sources.json` conserve onze références, leur version ou instant de consultation, le périmètre lu, les limites et leur contribution. Les documents en évolution sont des instantanés de documentation au 7 octobre 2026. Une expérience devra geler les binaires, profils, templates, avis et schémas compatibles ; consulter une version de manuel ne prouve pas que le binaire correspondant est disponible.

**Sans LLM et sans IA.** Une checklist, une comparaison de versions ou une logique conditionnelle peut ne contenir aucun apprentissage. « Sans LLM » inclut aussi des méthodes d'apprentissage statistique ou de planification classique, traitées dans les autres volets de l'étude. Le présent rapport se limite aux premiers mécanismes. Un outil constitue une implémentation ; la méthode est la transformation des données en décision, avec ses hypothèses. Comparer « Nmap contre LLM » sans préciser la tâche ne définit pas une expérience.

# 3 Ce que la sortie permet réellement d'affirmer

Le NIST sépare examen documentaire, test de comportement et entretien ; il recommande une méthode documentée et plusieurs techniques complémentaires. Sa revue distingue identification de services et analyse de vulnérabilités, et décrit les limites des signatures et des observations accessibles depuis un point réseau [1]. Pour LANCE, nous proposons de conserver cinq types de conclusions séparés dans l'évaluation (tableau 1).

| Objet évalué | Conclusion admissible | Conclusion supplémentaire non établie |
|---|---|---|
| Service observé | Réponse compatible avec un service, dans le point de vue et l'instant indiqués. | Vulnérabilité du logiciel ou absence de tout autre service. |
| Propriété de contrôle | Le comportement fourni respecte ou viole le critère testé. | Tous les chemins d'accès et toutes les identités sont couverts. |
| Configuration locale | Les éléments lus satisfont ou non une règle applicable. | Le comportement réseau effectif reproduit nécessairement cette configuration. |
| Applicabilité d'avis | Le produit identifié est couvert par un avis, sous ses conditions. | Une exploitation réussie ou un impact observé sur cette instance. |
| Capacité déclarée | Le document fourni décrit une capacité de sécurité. | Son implémentation et son efficacité ont été vérifiées. |

Table 1 – Taxonomie proposée pour les futures mesures. Les lignes désignent des tâches distinctes, pas des niveaux automatiquement ordonnés.

Un résultat inconnu ne doit pas devenir un cas sain. Le défaut d'information, la règle inapplicable et une observation contraire au critère ont des sens différents. Nous proposons d'évaluer explicitement l'abstention correcte : un système qui reconnaît une version inconnue peut être préférable à un système qui produit un diagnostic plausible mais sans justification.

# 4 Cinq familles de méthodes simples

## 4.1 Checklist contextualisée à critères explicites

**Fait sourcé.** NISTIR 8259A décrit six capacités : identification du dispositif, configuration, protection des données, accès logique aux interfaces, mise à jour logicielle et connaissance de l'état

de cybersécurité. Le tableau précise des éléments usuels et leur justification. Le document présente un point de départ à adapter au contexte ; il ne définit ni procédure universelle de test, ni obligation de mettre toutes les capacités en œuvre, ni certification [2].

**Référence proposée.** Une checklist simple peut préciser pour chaque propriété le critère applicable, le type de pièce attendu et les issues admises. Sur un dossier fourni, le moteur vérifie des champs et relations explicites : identité du produit, configuration du contrôle, observation datée, contexte d'usage. L'entrée doit inclure le même contexte public pour tous les bras ; elle n'inclut pas les réponses attendues du jeu de test. La sortie est une décision justifiée sur le critère, accompagnée d'une abstention lorsqu'une pièce indispensable manque.

L'intérêt pour LANCE serait une référence très lisible pour l'interprétation hors ligne : mêmes pièces, même objectif, aucun nouvel appel d'outil. Sa limite est la formulation des critères. Le travail humain qui traduit une capacité générale en critère vérifiable doit être recensé et gelé avant le test. Une checklist qui reprend les réponses des simulateurs serait compétente sur ceux-ci et faible comme preuve de transfert.

### 4.2 Inventaire et identification déterministes

**Fait sourcé.** Nmap distingue le nom probable associé à un port de l'identification obtenue à partir de réponses. Sa base de sondes et d'expressions cherche protocole, application et version, parfois une représentation CPE ; tous les services ne fournissent pas ces informations. La documentation relie aussi la couverture au niveau d'interrogation et précise que certains dispositifs ont des effets indésirables lors de l'identification [3]. Il s'agit d'identification, pas d'une preuve universelle de vulnérabilité.

**Référence proposée.** Réutiliser des résultats archivés et une petite base d'identification gelée pour mesurer exactitude et abstention sur des services connus. L'entrée serait la même trace ou sortie structurée pour tous les interprètes. La vérité terrain devrait être l'identité réelle de l'équipement au moment de la collecte, obtenue indépendamment des réponses observées. Les cas incluraient versions masquées, indices contradictoires, service derrière intermédiaire et port non habituel.

Cette méthode est une référence pour l'inventaire, et un socle d'audit. Comparer son nombre de services au nombre de conclusions d'A1 mélangerait deux objectifs. Un test d'interprétation de ses sorties pourrait mesurer l'apport du modèle, mais il ne mesurerait ni la découverte réseau ni la qualité des sondes. La maintenance porte surtout sur la base d'identification et les formats ; effort d'intégration faible si les artefacts existent, couverture des traces IoT à vérifier.

### 4.3 Contrôles protocolaires et templates conditionnels

**Fait sourcé.** Nuclei fournit des prédicats sur statut, contenu, expressions régulières, données binaires, XPath et expressions composées. Ses conditions permettent notamment conjonction, disjonction et exclusion [4]. Les workflows peuvent exécuter une étape selon un résultat précédent ou un matcher nommé [5]. Un branchement conditionnel ne nécessite donc pas un LLM ; sa qualité dépend des critères et des données qu'il interprète.

**Référence proposée.** Tester d'abord des prédicats de contrôle sur des réponses fournies : par exemple l'état de validité d'un certificat ou une politique d'accès explicitement donnée. Comparer une procédure fixe à des règles conditionnelles, sur une séquence préenregistrée dont les observations sont identiques lorsqu'une même étape est choisie. Aucun template opérationnel n'est fourni dans cette étude. Pour Nuclei comme outil externe, sélectionner seulement un corpus de contrôles bénins dont les sorties sont mappables à ces propriétés et faire vérifier ce corpus séparément.

Le succès d'un matcher signifie que sa condition est satisfaite. Une page générique, un intermédiaire ou une métadonnée trompeuse peut satisfaire une condition faible. Nous proposons donc des contre-exemples proches des positifs et un contrôle de l'identité du service dans le dossier. La base de templates et les extracteurs constituent une connaissance maintenue, à inventorier comme les prompts et connaissances du LLM. L'effort serait moyen pour une référence de qualité, même si le moteur est prêt à l'emploi.

C'est la famille la plus directement comparable à D1/A1 pour certaines propriétés déjà couvertes par les mêmes traces. L'outil externe ajoute une comparaison d'utilité du système ; l'attribution au LLM exige en plus le socle commun. Les protocoles ou propriétés sans contrôle admissible restent hors de son domaine mesuré, avec leur taux de couverture annoncé.

### 4.4 Conformité locale : OVAL et OpenSCAP

**Fait sourcé.** OVAL exprime des assertions sur l'état d'un système en séparant définitions, tests, objets collectés et valeurs attendues ; XCCDF organise les checklists et leurs références [6]. OpenSCAP évalue ces contenus. Son manuel distingue résultat conforme, non conforme, erreur, inconnu, inapplicable et non vérifié ; les données et variables du profil déterminent le sens du contrôle [7]. Ces issues ne doivent pas être fusionnées.

**Référence proposée.** Sur un export local fourni par l'opérateur, comparer une checklist adaptée à la plateforme et un LLM sur les mêmes propriétés. La sortie pourrait établir la non-conformité d'une option ou la présence d'un composant selon la règle applicable. Les cas devraient couvrir accès insuffisant, profil inadéquat, configuration manquante et configuration conforme. Les données simulant un export devront être clairement séparées des observations effectivement collectées.

Les profils génériques Linux ou Windows ne constituent pas automatiquement des profils de firmware IoT. Leur disponibilité, les mécanismes de collecte et la compatibilité des schémas doivent être vérifiés avant toute sélection. L'effort peut être faible pour une plateforme déjà couverte et élevé pour un firmware spécifique. Le contenu du profil, ses paramètres et ses exceptions sont la connaissance à maintenir.

Une configuration locale révèle des données qu'un audit réseau anonyme ne reçoit pas. OpenSCAP est donc une référence de conformité et un complément de système, pas un adversaire équitable d'A1 tant que les entrées diffèrent. Si une même pièce locale est remise aux deux bras, la comparaison devient recevable pour cette tâche restreinte ; elle ne généralise pas à l'audit réseau complet.

### 4.5 Inventaire logiciel et avis structurés : CPE, SBOM, CSAF, VEX

**Faits sourcés.** La NVD expose des critères CPE et plages de versions, avec identifiants et dates de modification [8]. CycloneDX représente composants, relations, provenance et complétude, y compris des inventaires incomplets ou inconnus ; sa notion de pedigree peut documenter des modifications et rétroportages [9]. CSAF distingue notamment produits affectés, non affectés, corrigés et sous investigation, et requiert des informations liées aux statuts du profil VEX [10]. VEX communique une appréciation d'applicabilité dans le contexte du produit [11].

**Référence proposée.** Créer une tâche hors ligne de rapprochement entre identités de composants fournies et avis figés. La décision attendue serait « applicable selon l'avis », « non applicable avec justification » ou « identité/contexte insuffisant ». Les cas devraient couvrir correspondance exacte, mauvais produit homonyme, borne de version, rétroportage connu, inventaire incomplet et avis contradictoires. Une politique conservatrice peut laisser la contradiction indéterminée ; le LLM reçoit les mêmes avis et ne dispose d'aucune recherche additionnelle.

Des avis identiques ne donnent pas aux deux bras des connaissances identiques : le LLM conserve celles de son préentraînement. Le gain éventuel concernerait donc cet interprète complet, sans

isoler un raisonnement pur. Un contrôle proposé emploierait des noms et avis fictifs cohérents, dont l'applicabilité résulte des seules pièces fournies. Des avis retenus hors du développement offriraient un autre contrôle ; leur date récente ne garantit cependant pas leur absence de l'apprentissage ou d'autres fuites. Ces conditions doivent rester distinctes dans les résultats.

L'identité d'une dépendance ne suffit pas à établir un impact observé. Une SBOM est un inventaire, un avis est une assertion de son producteur, et VEX ne remplace pas une vérification indépendante. La provenance et le périmètre du produit sont donc des entrées essentielles. Le coût à maintenir inclut dictionnaires d'identité, règles de comparaison de versions, schémas et avis. Il est moyen si les données existent, élevé si elles doivent être extraites de firmwares.

Cette méthode est très pertinente pour l'interprétation d'avis dans LANCE. Elle ne répond pas seule à la vérification de propriétés d'autorisation ou d'accès. Si le benchmark actuel ne fournit pas d'inventaire logiciel crédible, elle exige un corpus de données séparé ; l'étude ne présume pas que ce corpus est disponible.

## 5 Sélection proposée et cas de test

Le tableau 2 donne un ordre proposé, basé sur la compatibilité des entrées et la facilité de lire les erreurs. Les efforts sont qualitatifs et relatifs au dépôt ; ils ne constituent ni estimation de charge ni résultats mesurés. Commencer avec la méthode la plus compétente pour chaque propriété évite de faire du LLM la réponse par défaut.

**Acceptation préalable de la référence.** Sur le développement, faire valider les critères, contextes, négatifs proches, inconnus et justifications par un relecteur indépendant. Corriger les défauts révélés dans ce périmètre, puis figer règles, seuils et données avant le test réservé. Compter le travail de construction et de revue. Aucun correctif choisi après consultation du test ne rejoint la référence de cette comparaison ; une nouvelle version exige une nouvelle évaluation réservée.

| Ordre | Référence | Valeur scientifique immédiate | Effort / condition |
|---|---|---|---|
| 1 | Checklist à prédicats explicites | Interprétation de pièces communes ; erreurs compréhensibles. | Faible à moyen ; critères et dossiers indépendants à préparer. |
| 1 | D1, règles conditionnelles existantes | Apport marginal d'A1 sur le même socle. | Moyen ; connaissances des simulateurs et traces à auditer. |
| 2 | Contrôles protocolaires / templates gelés | Référence externe sur propriétés et protocoles communs. | Moyen ; corpus admissible, mapping et couverture à vérifier. |
| 2 | Matching inventaire–avis | Attribution sur une tâche d'applicabilité isolée. | Moyen ; inventaire fiable et avis figés nécessaires. |
| 3 | OVAL / OpenSCAP | Comparaison de conformité sur export local partagé. | Variable ; plateforme et profil compatibles indispensables. |
| Socle | Identification déterministe | Qualité de l'inventaire et inconnus à mesurer séparément. | Faible si traces présentes ; identité réelle indépendante. |

Table 2 – Priorités proposées. D1 est documenté dans le dépôt ; les autres intégrations ne sont pas annoncées comme implémentées.

**Fiches minimales de tests hors ligne.** Le tableau 3 précise six familles de dossiers fournis. Aucun identifiant de scénario n'est déclaré suffisant sans examen des données disponibles. Une revue d'éligibilité doit d'abord établir les pièces observables et l'oracle indépendant de chaque propriété.

Table 3: Cas proposés : observation ou configuration fournie, résultat attendu défini avant l'évaluation.

| Famille | Données communes et contrastes | Ce que la comparaison mesurerait |
|---|---|---|
| Checklist IoT | Capacité déclarée, pièce suffisante ou manquante, contexte d'usage explicite. | Application d'un critère et abstention ; pas certification complète. |
| Identité service | Trace authentifiée par provenance ; version annoncée, masquée ou contradictoire. | Exactitude de l'identification ; pas vulnérabilité confirmée. |
| Contrôle protocolaire | Réponse structurée avec politique attendue ; cas conforme, violation et format inattendu. | Classification d'une propriété et robustesse du parseur. |
| Décisions conditionnelles | Séquences bénignes préenregistrées ; réponse valide, refus ou erreur technique. | Différences de choix dans cet environnement de rejeu ; pas performance terrain. |
| Conformité locale | Export configuration, profil applicable ou inadéquat, champs connus ou absents. | Évaluation du critère et traitement des inconnus avec privilèges identiques. |
| Applicabilité avis | Inventaire logiciel, avis datés, versions limites, rétroportage et complétude. | Qualité du rapprochement et justification ; pas exploitabilité reproduite. |

Le rejeu de décisions ne doit pas inventer des réponses absentes : une branche sans observation devient hors couverture. Une réponse enregistrée n'est valable dans une autre branche que si l'historique et l'état restent compatibles. Restreindre le premier test aux lectures à effet nul avec réponses indépendantes de l'historique, ou aux histoires fournies et cohérentes ; toute transition sans réponse contrefactuellement justifiable reste hors couverture. Les enregistrements disponibles peuvent provenir des choix d'une politique et favoriser ces choix. Un test de rejeu doit publier ce biais, ou utiliser un environnement de données fourni dont toutes les branches admises sont connues indépendamment des politiques.

## 6 Mesures, exclusions et limites

**Mesures adaptées aux tâches.** Définir un univers de propriétés attendues sur les dossiers indépendamment des candidats produits par LANCE. Cet oracle doit inclure les propriétés omises et les pièces absentes à cause du collecteur : le rappel calculé seulement sur ses candidats masquerait ces pertes. Séparer l'échec de collecte du classement d'une pièce disponible, tout en les conservant dans la couverture du système complet. Rapporter exactitude des propriétés, vrais/faux positifs et négatifs, abstentions correctes ou incorrectes, erreurs et fraction du domaine couvert. Les preuves admises sont définies par propriété avant le test, avec revue indépendante d'un échantillon. Temps, coût modèle, calcul et travail de préparation doivent être distingués. Un nombre plus grand de conclusions ou un rapport plus fluide ne prouve pas une meilleure détection.

Pour l'interprétation hors ligne, les pièces sont strictement communes. Pour une future comparaison d'audit complet, le point de vue initial, les outils admis et les budgets doivent être comparables ; les observations ultérieures peuvent diverger selon les décisions. L'effet du modèle est alors un effet de politique dans ce dispositif, pas une mesure de son raisonnement abstrait. Les répétitions d'un même dossier ne constituent pas de nouvelles familles d'équipements.

**Exclusions justifiées.**

— Les analyseurs statiques de firmware et les fuzzers spécialisés nécessitent binaires, sources, instrumentation ou interfaces différentes. Ils sont pertinents pour d'autres tâches ; leur exclusion du premier comparatif vient du désalignement des entrées et du succès attendu.
— Un outil de conformité locale n'est pas utilisé comme référence anonyme si lui seul reçoit des privilèges administratifs. Il reste proposé pour une comparaison avec exports locaux communs.
— Un scanner généraliste sans contrôle du protocole considéré est exclu de ce sous-ensemble comparatif ; sa couverture limitée reste rapportée dans l'évaluation d'utilité globale.
— Les outils de détection d'anomalies sur flux ne partagent ni les données ni l'objectif d'un audit ponctuel. Une étude temporelle dédiée pourrait les examiner.
— Une déclaration fabricant, une correspondance de version et un score de sévérité ne sont pas utilisés comme preuve d'accès effectif. Ils peuvent soutenir des décisions de gestion de risque différentes.

**Réserves de la revue.** Cette sélection n'est pas une revue systématique exhaustive ; aucun score de performance publié n'est transposé à LANCE. Les documentations officielles prouvent des mécanismes décrits, pas leur implémentation correcte sur tout équipement. La faisabilité des profils IoT, la couverture réelle des templates bénins et la qualité des SBOM restent ouvertes. Le dépôt contient des changements locaux et conflits préexistants, conservés ; les références D1/A1 sont celles des guides lus et non une validation du code courant.

# 7 Conclusion et prochaines étapes

La référence initiale devrait combiner une checklist ou des prédicats compétents par propriété, les règles conditionnelles D1 déjà documentées, et un test d'interprétation hors ligne à pièces identiques. Les outils externes doivent ensuite être sélectionnés pour leur couverture admissible, avec OpenSCAP et le matching d'avis réservés aux entrées qu'ils exigent. Ce programme peut produire un résultat négatif instructif : si les règles suffisent, l'usage du LLM sur cette propriété n'est pas justifié par un gain technique démontré.

Avant de retenir des expériences, faire challenger indépendamment la force des règles, l'éligibilité des pièces et l'indépendance des oracles ; vérifier sur quelques dossiers que les erreurs et inconnus restent visibles. La présente livraison apporte des références et des tâches à tester. Elle ne met en œuvre aucun nouveau contrôleur et ne rapporte aucune plus-value mesurée.

# Références


[1] Scarfone, Souppaya, Cody et Orebaugh, NIST SP 800-115, septembre 2008. Lecture ciblée : résumé exécutif, §2.1–2.2 et §4.1–4.3 (limites des scans). https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-115.pdf.

[2] Fagan, Megas, Scarfone et Smith, NISTIR 8259A, mai 2020. Lecture : introduction, §2, tableau 1, annexe A. https://nvlpubs.nist.gov/nistpubs/ir/2020/NIST.IR.8259A.pdf.

[3] Nmap, *Service and Version Detection*. Documentation consultée le 7 octobre 2026 ; section mécanismes et limites. https://nmap.org/book/man-version-detection.html.

[4] ProjectDiscovery, *Matchers*. Instantané documentaire du 7 octobre 2026 ; types, conditions négatives et composition des matchers. https://docs.projectdiscovery.io/templates/reference/matchers.

[5] ProjectDiscovery, *Template Workflows Overview*. Instantané du 7 octobre 2026 ; workflows génériques et conditionnels. https://docs.projectdiscovery.io/templates/workflows/overview.

[6] OVAL Community, *Getting Started*, documentation 5.12.3. Lecture : définition, structure, caractéristiques et standards liés ; pas validation d'un interpréteur. https://oval-community-guidelines.readthedocs.io/en/v5.12.3/getting-started.html.

[7] OpenSCAP, *User Manual*, chemin documentaire 1.4.1 ; §4.2–4.4, résultats XCCDF et aperçu du tailoring §6. https://static.open-scap.org/openscap-1.4.1/oscap_user_manual.html.

[8] NIST NVD, *Product APIs*. Lecture ciblée de la page indexée : Match Criteria API, plages et métadonnées ; l'ouverture suivante a renvoyé une page vide. https://nvd.nist.gov/developers/products.

[9] OWASP CycloneDX, *Authoritative Guide to SBOM*, troisième édition, 21 octobre 2025 (CycloneDX 1.7). Lecture : définition et inventaire ; pedigree et complétude, pages imprimées 63–66. https://cyclonedx.org/guides/sbom/consumption.

[10] OASIS, *Common Security Advisory Framework Version 2.0*, standard du 18 novembre 2022. Lecture ciblée : §3.2.3.9 et contraintes VEX §6.1.27.7–8 ; pas lecture intégrale. https://docs.oasis-open.org/csaf/csaf/v2.0/os/csaf-v2.0-os.html.

[11] OWASP CycloneDX, *Vulnerability Exploitability eXchange*. Page descriptive lue ; instantané du 7 octobre 2026, pas validation normative de VEX. https://www.cyclonedx.org/capabilities/vex/.